

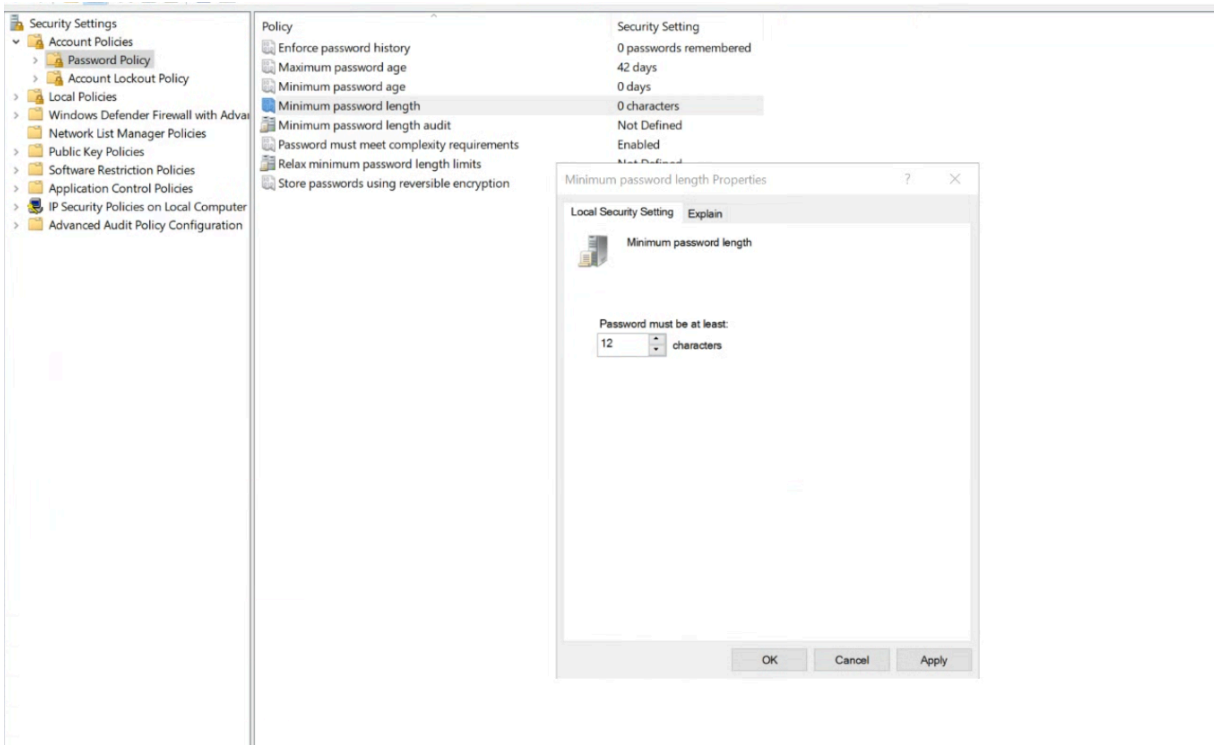
Hardening Windows Servers

Dominic Yeakel & Ryan Carter

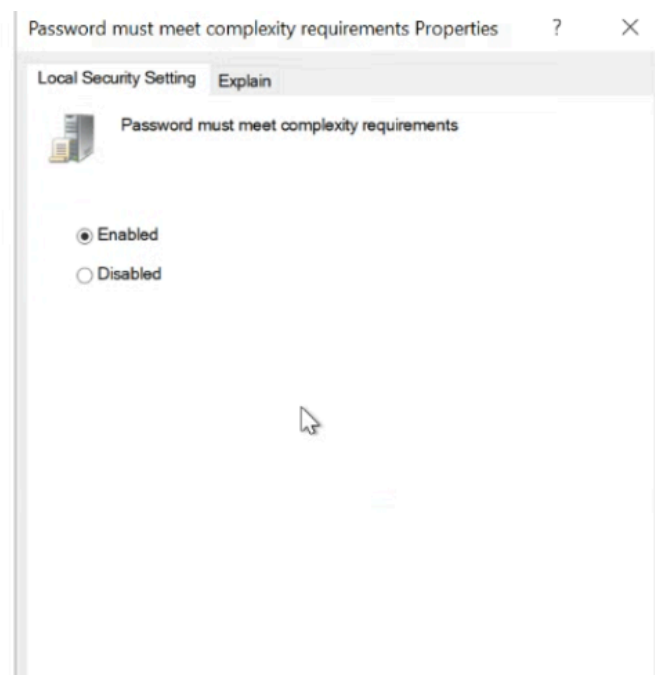
Instructor: Andry Rakotomalala

Part 1: Local Security Policy

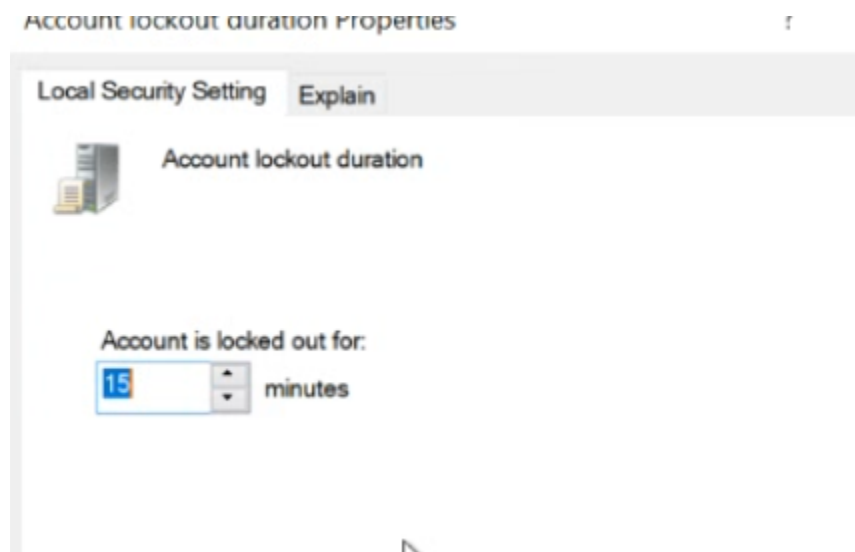
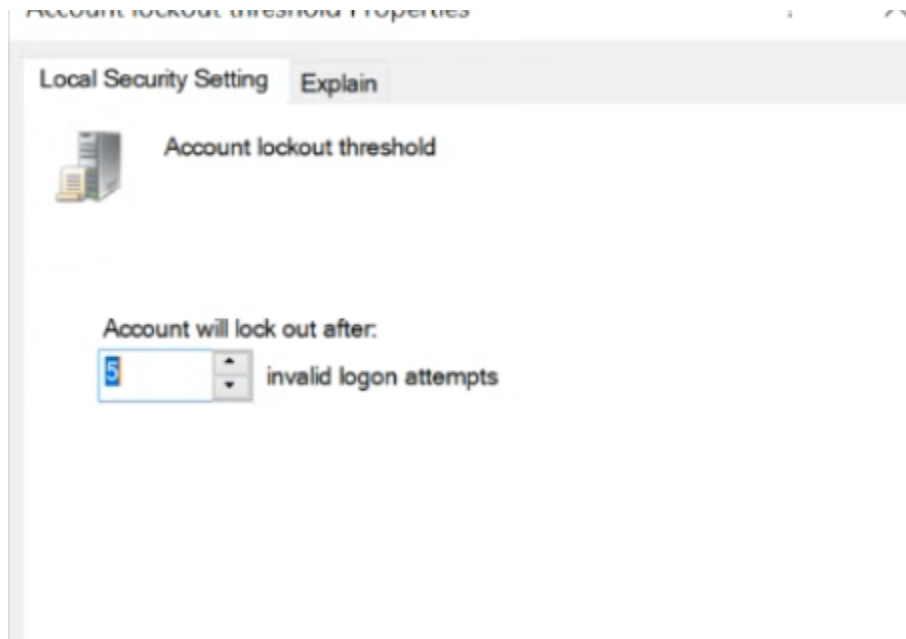
1. Open Local Security Policy and review the current password policy (minimum length, complexity, maximum age).



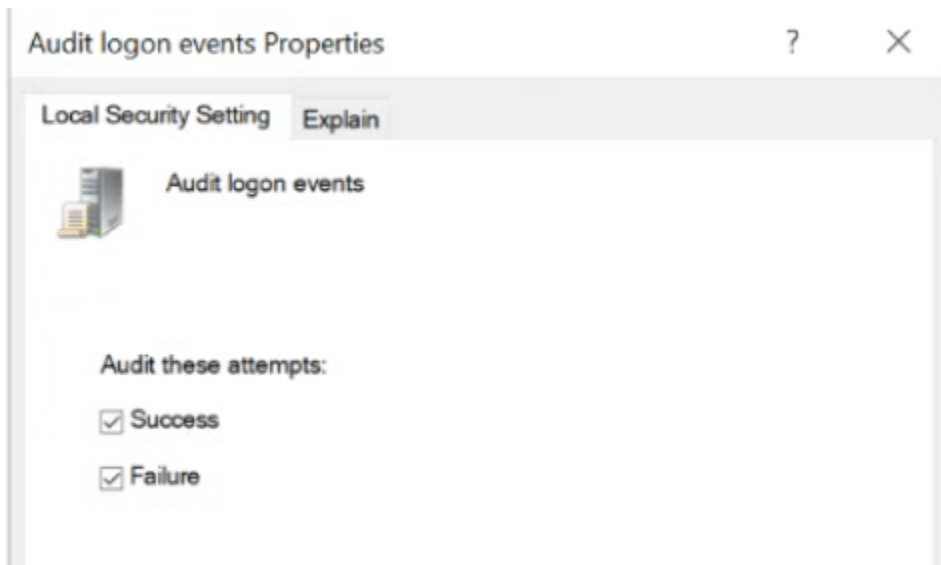
2. Set a minimum password length of at least 12 characters with complexity requirements enabled.



3. Configure account lockout policy: lock the account after 5 invalid attempts, with a minimum 15-minute lockout duration.

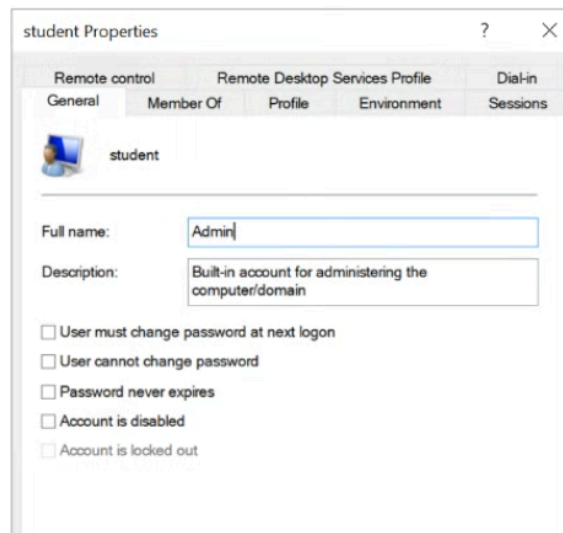
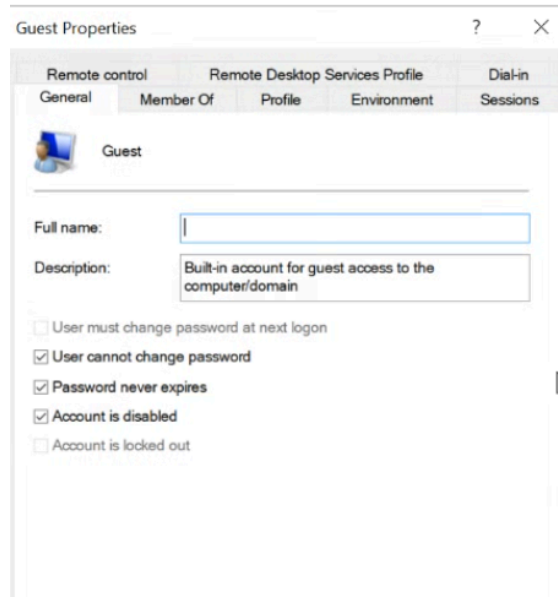


4. Enable auditing for logon events (both success and failure) under Local Policies > Audit Policy.

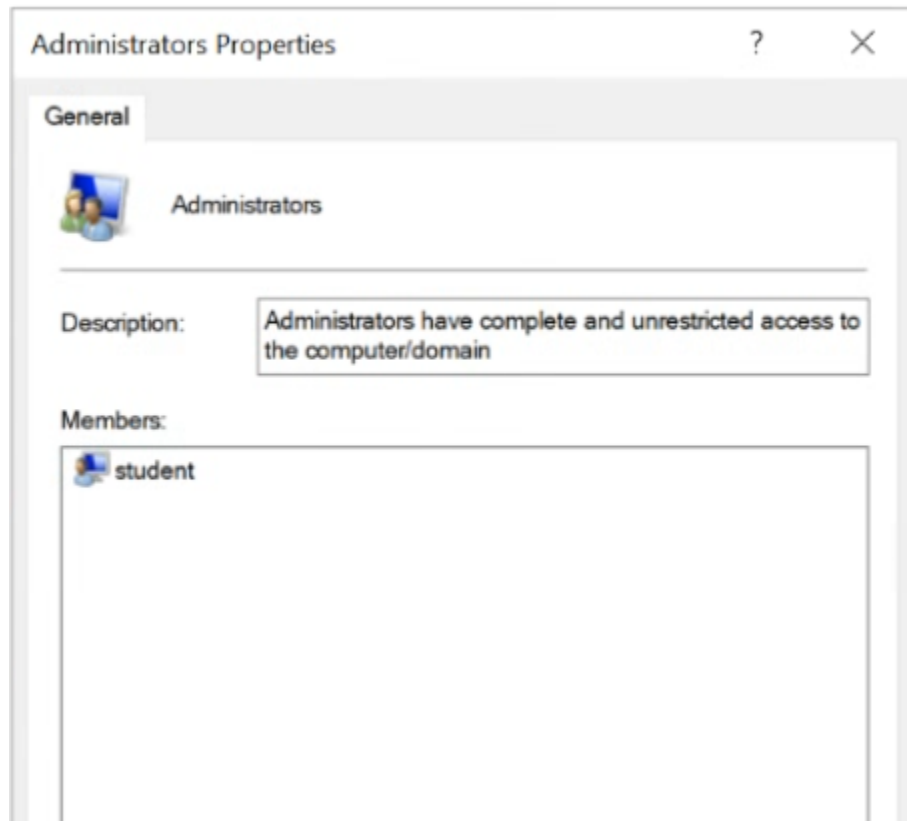


Part 2: User, Group, and Service Hardening

1. Review local users (lusrmgr.msc): disable the built-in Guest account if enabled, and rename the built-in Administrator account.

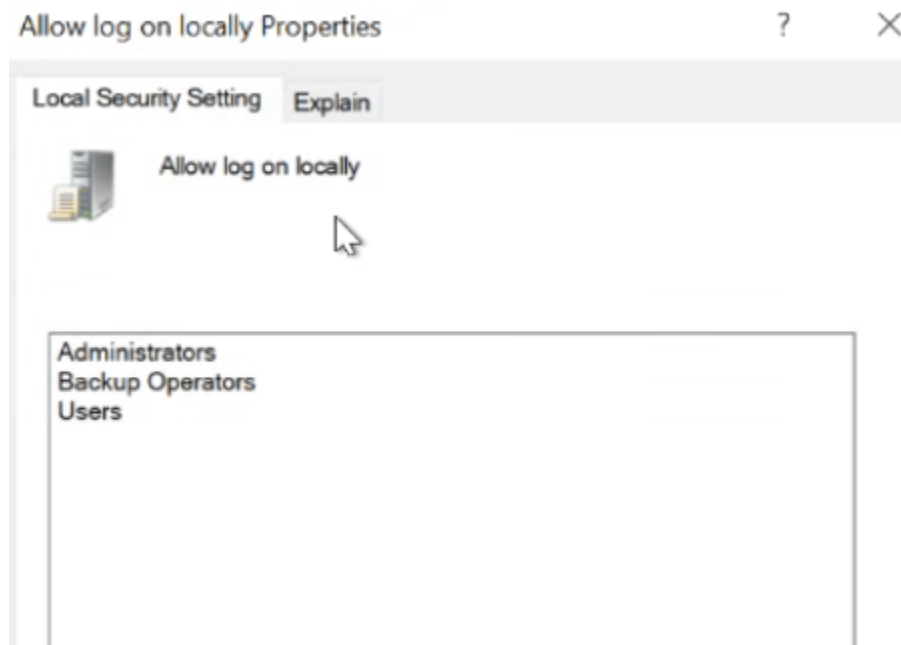


2. Review local group membership, especially Administrators, and remove any account that doesn't need standing admin access.

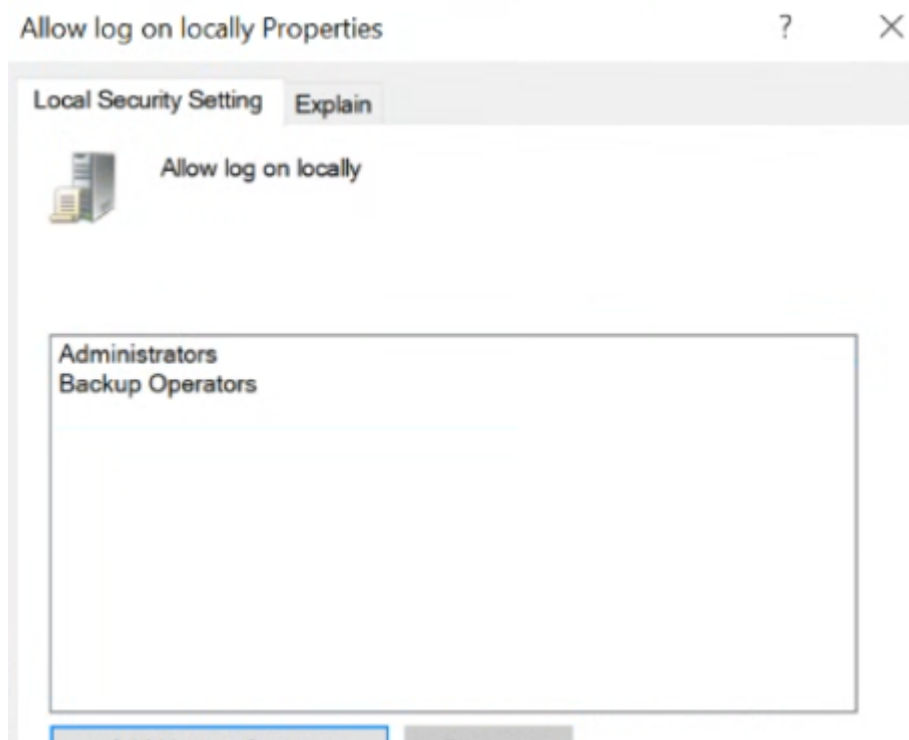


3. Review User Rights Assignment for "Log on locally" and "Access this computer from the network," and restrict them to only the accounts/groups that need them.

Before:

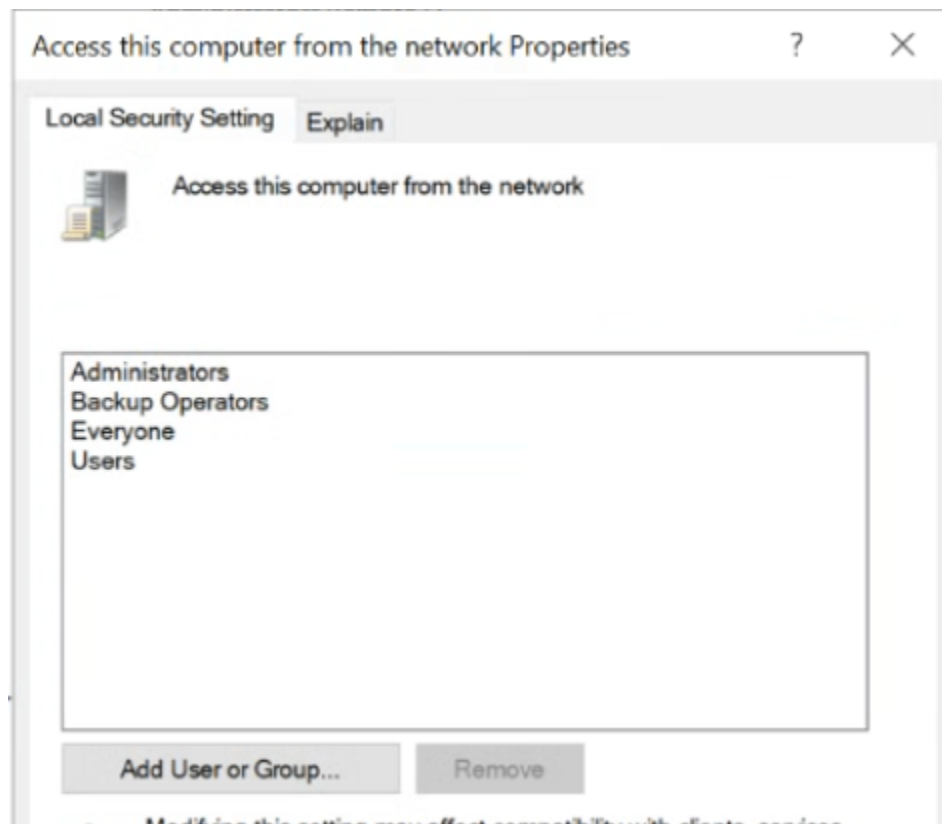


After:

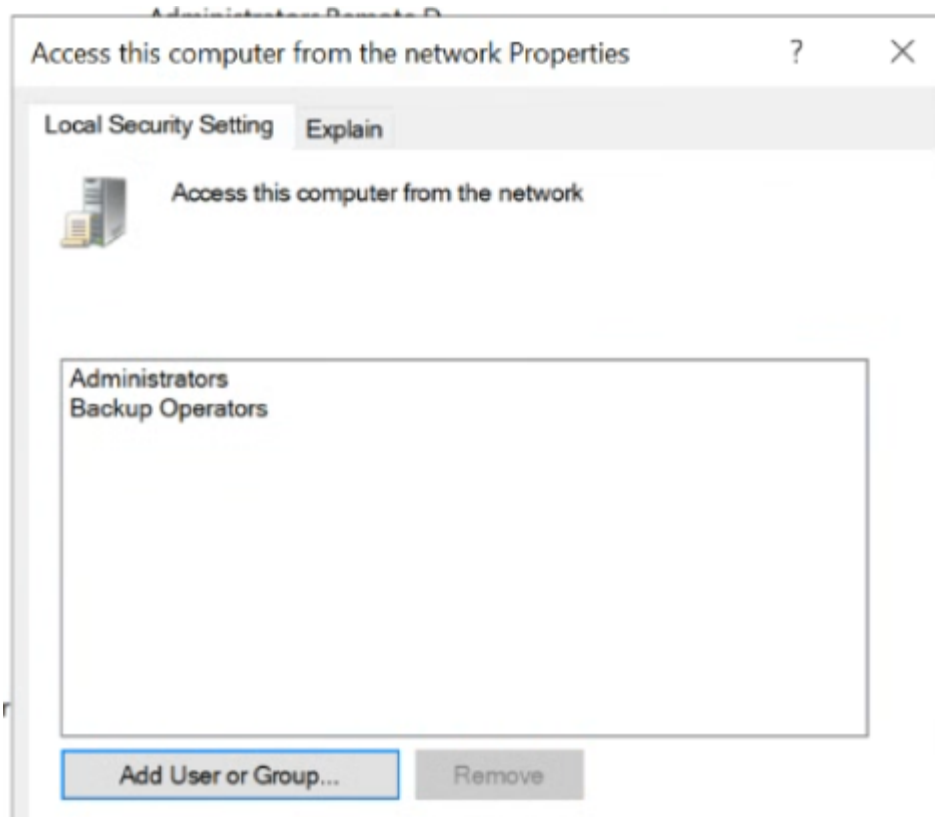


Removed users, this was to broad

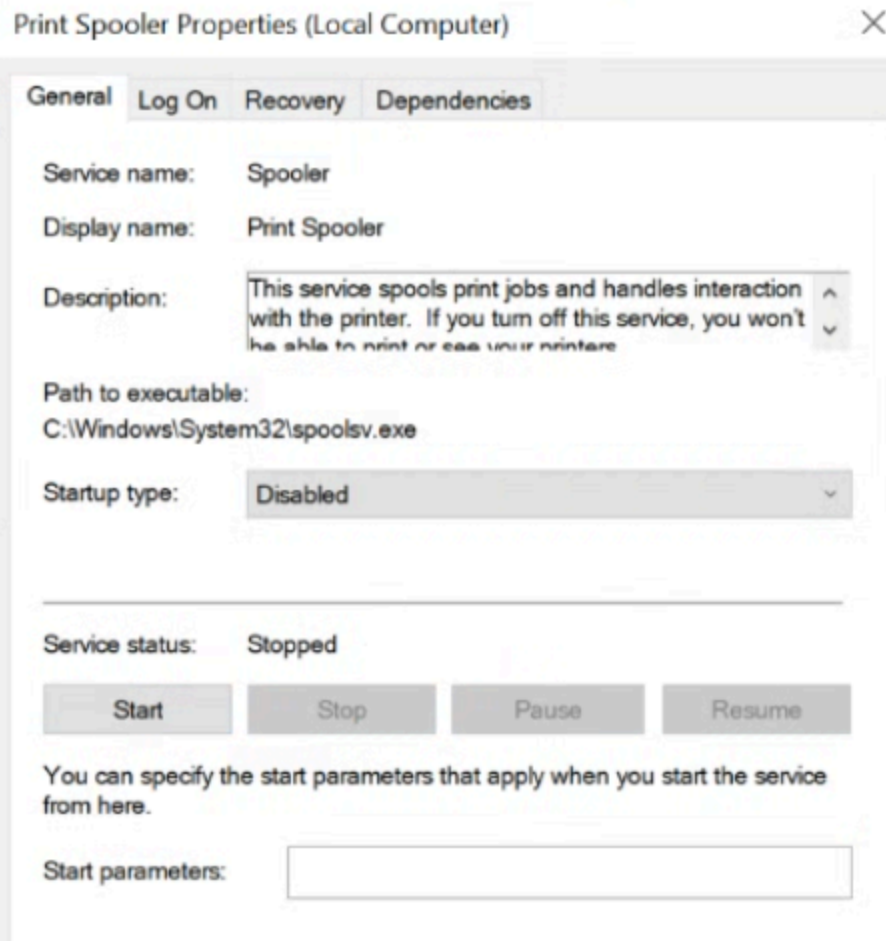
Before:



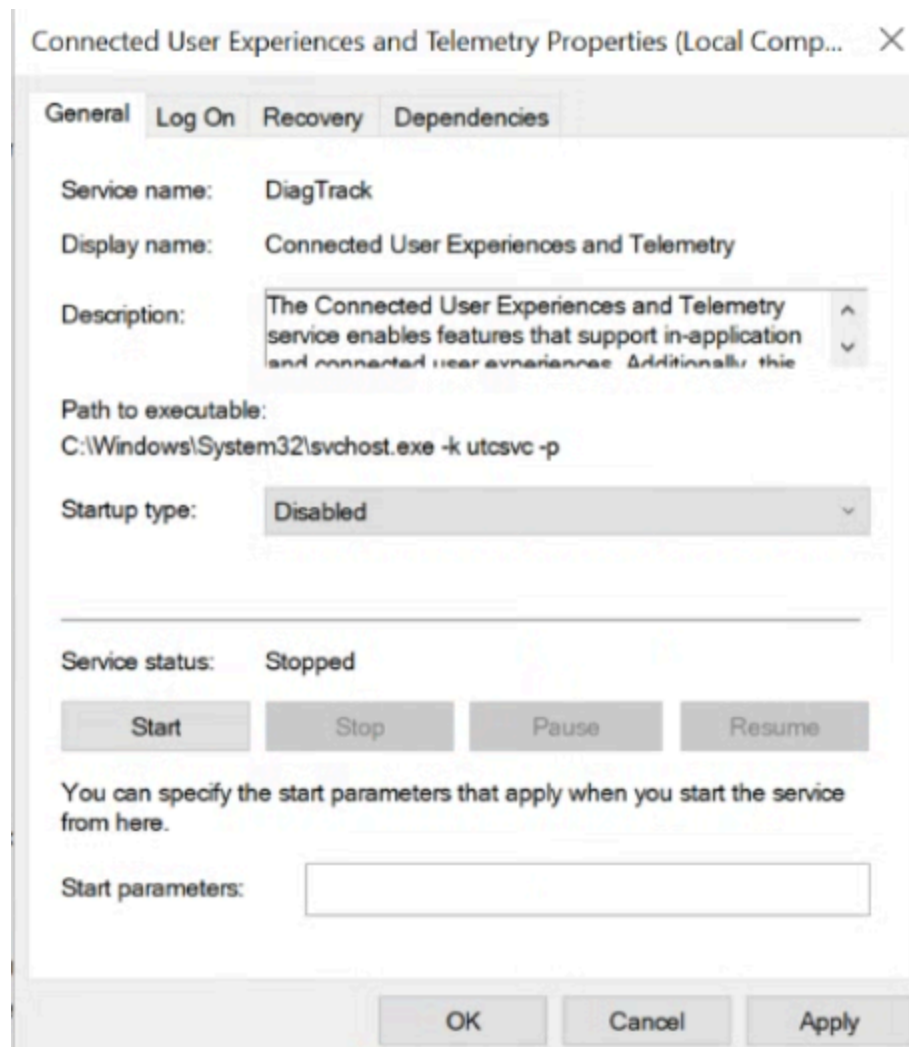
After:



4. Review running services (services.msc), identify at least two that aren't needed for this host's role, and disable them.



This host does not require printing for its intended role. Disabling Print Spooler removes an unnecessary service and reduces the attack surface.



Diagnostic telemetry was not required for the host's intended role. Disabling DiagTrack removes an unnecessary background service and reduces unnecessary data collection and network communication.

5. Review Windows Firewall with Advanced Security inbound rules, and disable or remove any rule that allows unnecessary inbound access.

Before:

Cast to Device streaming server (RTSP-Streaming-In)	Cast to Device functionality	Domain	Yes	Allow	No	%System...	Any
Cast to Device streaming server (RTSP-Streaming-In)	Cast to Device functionality	Public	Yes	Allow	No	%System...	Any
Cast to Device streaming server (RTSP-Streaming-In)	Cast to Device functionality	Private	Yes	Allow	No	%System...	Any
Cast to Device streaming server (RTCP-Streaming-In)	Cast to Device functionality	Public	Yes	Allow	No	%System...	Any
Cast to Device streaming server (RTCP-Streaming-In)	Cast to Device functionality	Private	Yes	Allow	No	%System...	Any
Cast to Device streaming server (RTCP-Streaming-In)	Cast to Device functionality	Domain	Yes	Allow	No	%System...	Any
Cast to Device streaming server (HTTP-Streaming-In)	Cast to Device functionality	Domain	Yes	Allow	No	System	Any
Cast to Device streaming server (HTTP-Streaming-In)	Cast to Device functionality	Private	Yes	Allow	No	System	Any
Cast to Device streaming server (HTTP-Streaming-In)	Cast to Device functionality	Public	Yes	Allow	No	System	Any
Cast to Device SSDP Discovery (UDP-In)	Cast to Device functionality	Public	Yes	Allow	No	%System...	Any
Cast to Device functionality (qWave-UDP-In)	Cast to Device functionality	Private, Public	Yes	Allow	No	%System...	Any
Cast to Device functionality (qWave-TCP-In)	Cast to Device functionality	Private, Public	Yes	Allow	No	%System...	Any

Media casting is not required for this host's role. Disabling the rule removes unnecessary inbound access related to media streaming and device discovery.

AllJoyn Router (UDP-In)	AllJoyn Router	Domain, Private	Yes	Allow	No	%System...	Any
AllJoyn Router (TCP-In)	AllJoyn Router	Domain, Private	Yes	Allow	No	%System...	Any

Device-to-device discovery is unnecessary for this system. Disabling it reduces unnecessary network communication and attack surface.

mDNS (UDP-In)	mDNS	Public	Yes	Allow	No	%System...	Any
mDNS (TCP-In)	mDNS	Public	Yes	Allow	No	%System...	Any

Automatic device discovery is not needed for this host. Blocking inbound mDNS reduces unnecessary discovery traffic and prevents the system from being unnecessarily visible to other devices.

DIAL protocol server (HTTP-In)	DIAL protocol server	Private	Yes	Allow	No	System	Any
DIAL protocol server (HTTP-In)	DIAL protocol server	Domain	Yes	Allow	No	System	Any

The host does not need to communicate with or launch applications on streaming devices, so allowing inbound DIAL traffic serves no business purpose.

Microsoft Media Foundation Network Source IN [UDP 5004-5009]	Microsoft Media Foundation...	All	Yes	Allow	No	%System...	Any
Microsoft Media Foundation Network Source IN [TCP 554]	Microsoft Media Foundation...	All	Yes	Allow	No	%System...	Any
Microsoft Edge (mDNS-In)	Microsoft Edge	All	Yes	Allow	No	C:\Progra...	Any

Network media streaming is not required for the host's business function. Disabling it removes an unnecessary inbound communication path.

Desktop App Web Viewer	Desktop App Web Viewer	All	Yes	Allow	No	Any	Any
Desktop App Web Viewer	Desktop App Web Viewer	All	Yes	Allow	No	Any	Any

Allows certain Windows desktop applications that display web-based content to communicate through the firewall. This inbound access was not required for the host's intended role, so the rule was disabled to follow least-privilege principles.

Delivery Optimization (UDP-In)	Delivery Optimization	All	Yes	Allow	No	%System...	Any
Delivery Optimization (TCP-In)	Delivery Optimization	All	Yes	Allow	No	%System...	Any

Peer-to-peer update sharing was not necessary for this host. Disabling inbound access prevents the computer from acting as a source for update distribution to other machines.

After:

✓ Your account	Your account	Domain, Private	Yes	Allow	No	Any	Any
✓ Your account	Your account	Domain, Private	Yes	Allow	No	Any	Any
✓ Work or school account	Work or school account	Domain, Private	Yes	Allow	No	Any	Any
✓ Work or school account	Work or school account	Domain, Private	Yes	Allow	No	Any	Any
✓ Windows Security	Windows Security	Domain, Private	Yes	Allow	No	Any	Any
✓ Windows Security	Windows Security	Domain, Private	Yes	Allow	No	Any	Any
✓ Windows Search	Windows Search	Domain, Private	Yes	Allow	No	Any	Any
✓ Windows Search	Windows Search	Domain, Private	Yes	Allow	No	Any	Any
✓ Windows Remote Management (HTTP-In)	Windows Remote Managem...	Public	Yes	Allow	No	System	Any
✓ Windows Remote Management (HTTP-In)	Windows Remote Managem...	Domain, Private	Yes	Allow	No	System	Any
✓ Start	Start	Domain, Private	Yes	Allow	No	Any	Any
✓ Start	Start	Domain, Private	Yes	Allow	No	Any	Any
✓ Remote Desktop - User Mode (UDP-In)	Remote Desktop	All	Yes	Allow	No	%System...	Any
✓ Remote Desktop - User Mode (TCP-In)	Remote Desktop	All	Yes	Allow	No	%System...	Any
✓ Remote Desktop - Shadow (TCP-In)	Remote Desktop	All	Yes	Allow	No	%System...	Any
✓ Core Networking - Time Exceeded (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Teredo (UDP-In)	Core Networking	All	Yes	Allow	No	%System...	Any
✓ Core Networking - Router Solicitation (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Router Advertisement (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Parameter Problem (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Packet Too Big (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Neighbor Discovery Solicitation (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Neighbor Discovery Advertisement (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Multicast Listener Report v2 (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Multicast Listener Report (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Multicast Listener Query (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Multicast Listener Done (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - IPv6 (IPv6-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - IPHTTPS (TCP-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Internet Group Management Protocol (IGMP-In)	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Dynamic Host Configuration Protocol for IPv6...	Core Networking	All	Yes	Allow	No	%System...	Any
✓ Core Networking - Dynamic Host Configuration Protocol (DHCP-In)	Core Networking	All	Yes	Allow	No	%System...	Any
✓ Core Networking - Destination Unreachable Fragmentation Need...	Core Networking	All	Yes	Allow	No	System	Any
✓ Core Networking - Destination Unreachable (ICMPv6-In)	Core Networking	All	Yes	Allow	No	System	Any

Part 3: BitLocker Drive Encryption

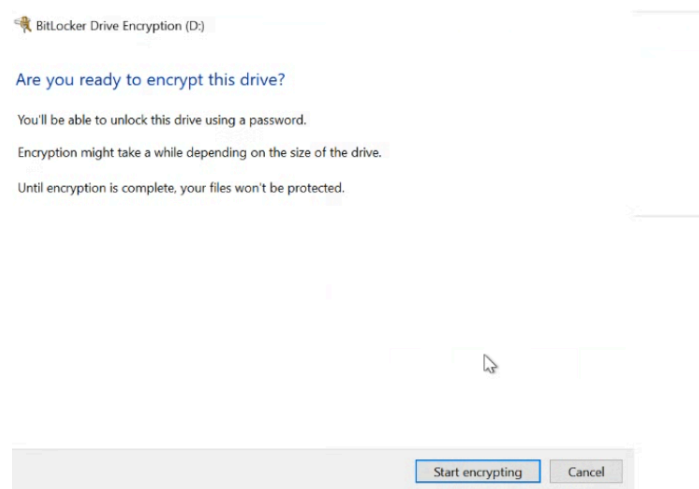
1. Confirm TPM availability on the host (tpm.msc or Get-Tpm in PowerShell).

```
PS C:\Users\student> Get-Tpm

TpmPresent           : True
TpmReady             : True
TpmEnabled           : True
TpmActivated         : True
TpmOwned             : False
RestartPending      : False
ManufacturerId       : 1297303124
ManufacturerIdTxt    : MSFT
ManufacturerVersion  : 8224.786.18.4
ManufacturerVersionFull120 : 8224.786.18.4

ManagedAuthLevel    : Full
OwnerAuth            :
OwnerClearDisabled   : False
AutoProvisioning     : Enabled
LockedOut            : False
LockoutHealTime      : 16 minutes 40 seconds
LockoutCount         : 0
LockoutMax           : 3
SelfTest             : {}
```

2. Enable BitLocker on the data volume containing sensitive file shares, choosing an appropriate authentication method (TPM, or TPM + PIN).



3. When prompted, save the BitLocker recovery key to a secure location provided by your instructor — never leave it on the encrypted drive itself.
4. Monitor encryption progress and confirm it completes: `manage-bde -status`

```
PS C:\Users\student> manage-bde -status
BitLocker Drive Encryption: Configuration Tool version 10.0.20348
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

Disk volumes that can be protected with
BitLocker Drive Encryption:
Volume C: [Windows]
[OS Volume]

    Size: 126.45 GB
    BitLocker Version: None
    Conversion Status: Fully Decrypted
    Percentage Encrypted: 0.0%
    Encryption Method: None
    Protection Status: Protection Off
    Lock Status: Unlocked
    Identification Field: None
    Key Protectors: None Found

Volume D: [Temporary Storage]
[Data Volume]

    Size: 32.00 GB
    BitLocker Version: 2.0
    Conversion Status: Fully Encrypted
    Percentage Encrypted: 100.0%
    Encryption Method: XTS-AES 128
    Protection Status: Protection On
    Lock Status: Unlocked
    Identification Field: Unknown
    Automatic Unlock: Disabled
    Key Protectors:
        Password
        Numerical Password
```

Part 4: Verification Script

Write a PowerShell script (Verify-Hardening.ps1) that checks the host against today's changes and reports PASS/FAIL for each. At minimum, it should check:

- That the Guest account is disabled
- That the built-in Administrator account has been renamed
- That the configured password minimum length meets policy
- That BitLocker is enabled and fully encrypted on the target volume

1. Run your script and capture its output as evidence.

 Verify-Hardening - Notepad

File Edit Format View Help

Write-Host "Meridian Trust Bank - Windows Hardening Verification"

```
$guest = Get-LocalUser -Name "Guest" -ErrorAction SilentlyContinue
if ($guest -and $guest.Enabled -eq $false) {
    Write-Host "[PASS] Guest account is disabled"
} else {
    Write-Host "[FAIL] Guest account is not disabled"
}

$admin = Get-LocalUser | Where-Object { $_.SID -like "*-500" }
if ($admin.Name -ne "Administrator") {
    Write-Host "[PASS] Built-in Administrator account has been renamed"
} else {
    Write-Host "[FAIL] Built-in Administrator account still uses the default name"
}

$policy = (net accounts | Select-String "Minimum password length")
if ($policy -match "(\d+)") {
    $minLen = [int]$matches[1]
    if ($minLen -ge 12) {
        Write-Host "[PASS] Minimum password length is $minLen (policy requires 12+)"
    } else {
        Write-Host "[FAIL] Minimum password length is $minLen, policy requires 12+"
    }
} else {
    Write-Host "[FAIL] Could not read password length policy"
}

$bitlocker = manage-bde -status | Select-String "Percentage Encrypted"
if ($bitlocker -match "100") {
    Write-Host "[PASS] BitLocker is fully encrypted on the target volume"
} else {
    Write-Host "[FAIL] BitLocker is not fully encrypted yet"
}

Write-Host "Check complete"
```

```
Check complete
PS C:\Users\student\Downloads> pwd

Path
----
C:\Users\student\Downloads

PS C:\Users\student\Downloads> .\Verify-Hardening.ps1
Meridian Trust Bank - Windows Hardening Verification
[PASS] Guest account is disabled
[PASS] Built-in Administrator account has been renamed
[PASS] Minimum password length is 12 (policy requires 12+)
[PASS] BitLocker is fully encrypted on the target volume
Check complete
```

2. Fix anything your own script flags as a FAIL before submitting.
 - No fails, everything passed

1. Why is renaming the built-in Administrator account and disabling Guest considered a baseline step rather than optional hardening?

Since attackers know that the defaults are Administrator and Guest, leaving them unchanged makes guessing the usernames or abusing any weak access easier. Renaming Administrator and disabling Guest reduces unnecessary exposure.

2. What's the practical difference in risk between an unencrypted drive that's access-controlled and an encrypted drive like the one you set up today? When does BitLocker actually matter?

An unencrypted drive that's access-controlled does not protect against physical attacks on the drive. A threat actor with physical access to this drive would be able to access the contents since the drive only protects access when the operating system is running and enforcing access. An encrypted drive protects the data even if the threat actor has physical access to the drive. Unless the threat actor has the encryption key, there is no way for them to decrypt the data. BitLocker matters when protecting against physical access to the drive.

3. If you lost the BitLocker recovery key in a real production environment, what would that mean for the bank — and how does that change how you'd store it?

In a production environment losing the recovery key would cause downtime, data loss, and major business impact. Because of that immense loss, recovery keys should be securely backed up in a controlled and secure location or an approved enterprise key-management system, with access limited to authorized personnel.